

WHAT CHANGED

Inbound email routing is no longer guessable

A predictable engagement ID used to be enough to influence automatic routing. The fix adds a secret-backed signed marker, requires a recognized sender before automation, and records the gateway - not the From header - as the Chron actor.



New automatic-routing rule

One valid signed marker for an active Engagement **AND** a sender address that the application recognizes. If either gate fails, the message waits for manual review.

BEFORE

Predictable marker

[MOED#42]

- Anyone who guessed an ID could construct the marker.
- Unknown senders could reach an Engagement Chron automatically.
- A visible From value could be attributed like an internal identity.

AFTER

Signed routing capability

[MOED#42. <22-char-token>]

- The tag depends on a 32-byte deployment secret.
- Unknown, unsigned, altered, conflicting, or inactive routes stop for review.
- Inbound entries are attributed to **Email Gateway** with no user ID.

The fix uses three independent controls

1 Signed route

The Engagement ID is bound to a keyed HMAC tag that cannot be generated from the ID alone.

2 Automation gate

Even a valid marker does not auto-route unless the sender address resolves as a recognized active record.

3 Neutral attribution

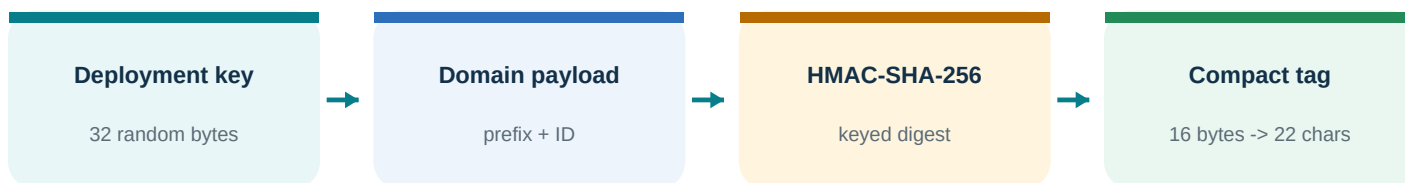
The From header is retained as message data, but never becomes the authenticated Chron creator.

CONTROL 1

How the signed marker is made and checked

The marker is a compact routing capability. It proves that the route token was produced by this deployment for this exact prefix and Engagement ID; it does not prove who sent the email.

Generation pipeline



Exact construction used by MOED

```
payload = "dnr-inbound-routing-v1\0" + lowercase(prefix) + "\0" + engagement_id
digest = HMAC-SHA-256(deployment_key, payload)
tag = Base64URL(first 16 bytes of digest), without padding
marker = [MOED#engagement_id.tag]
```

What is bound into the signature

- A versioned domain string keeps this HMAC separate from any other use of the key.
- The normalized marker prefix prevents a tag from being silently reused under a different namespace.
- The Engagement ID prevents a valid token for one Engagement from authorizing another.

How validation fails closed

- The parser requires an ID plus exactly 22 Base64URL characters.
- It recomputes the expected tag and compares it with **hash_equals**.
- Unsigned legacy markers, modified tokens, multiple distinct targets, and inactive targets are not authoritative.



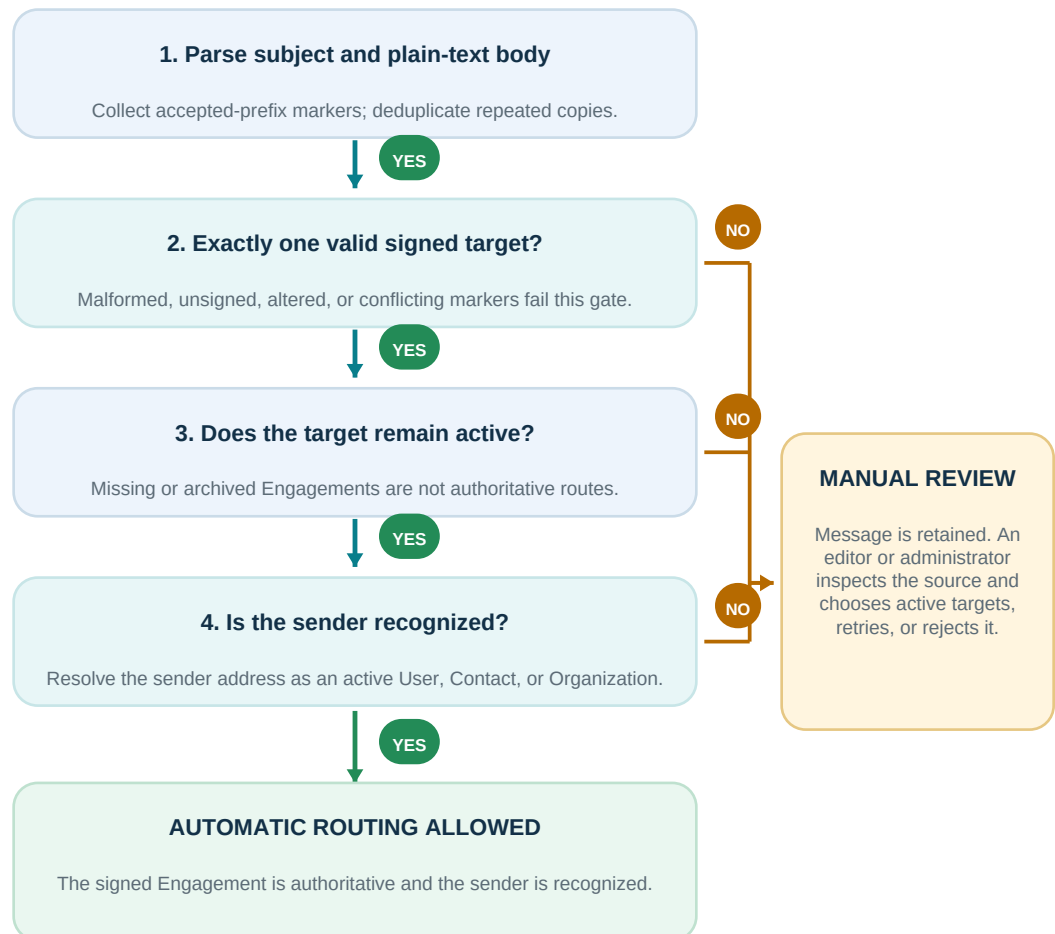
Outbound mail keeps the route canonical. Before sending, MOED removes an existing accepted marker from the subject and appends the correct signed marker for the selected Engagement. A marker for another Engagement is rejected.

CONTROL 2

How an inbound message is routed now

The application treats marker validity and sender recognition as separate gates. Passing one never substitutes for passing the other.

Automatic-routing decision



What gets written when automation is allowed

CLEAN MATCH

The application can apply the matched Contact, Organization, and signed Engagement routes.

PARTICIPANT UNCERTAINTY

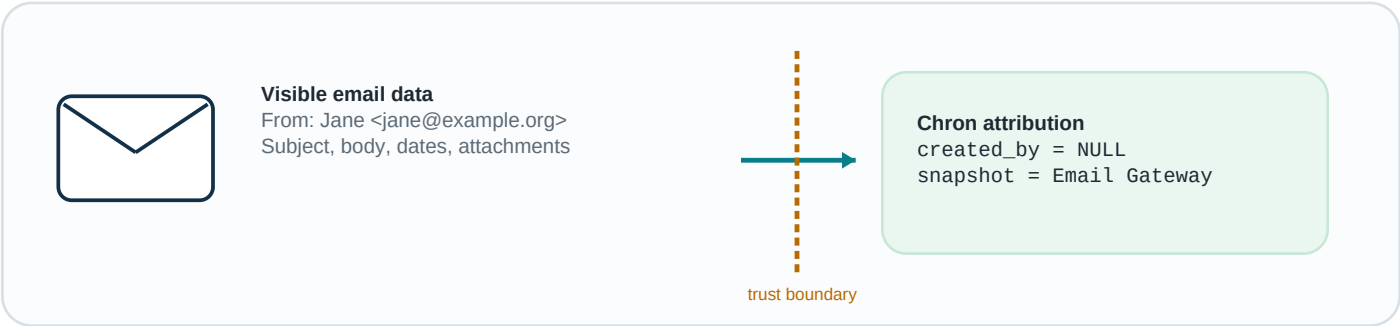
The application limits the write to the authoritative signed Engagement, avoiding speculative Contact or Organization writes.

Important: the marker is searched in both the subject and plain-text body so normal reply behavior is supported. Repeated copies of the same valid marker are deduplicated; two distinct Engagement targets are treated as a conflict.

CONTROL 3

Attribution is separated from message content

Email headers are useful evidence and routing hints, but they are not an authenticated MOED session. The fix preserves the original From details while refusing to turn them into an internal user identity.



Examples of the new behavior

MARKER	SENDER	RESULT
[MOED#42] Unsigned and sender not recognized.	unknown address	✗ REVIEW
valid signed marker A valid routing capability alone is not enough for automation.	unknown address	✗ REVIEW
altered signed marker A recognized sender cannot rescue an invalid token.	recognized address	✗ REVIEW
valid signed marker Both independent gates pass; destination scope still follows routing checks.	recognized address	✓ AUTO-ROUTE

What the patch now guarantees

- An Engagement ID alone cannot produce an accepted automatic route.
- Marker tampering is detected with a constant-time comparison.
- Unknown senders do not auto-route, and From does not impersonate a MOED user.

What remains outside that guarantee

- The marker is a bearer-style routing capability, not proof of sender identity.
- Someone who obtains a valid marker can reuse it; sender recognition remains the second gate.
- Upstream SPF, DKIM, and DMARC enforcement still matters against spoofed recognized addresses.

Implementation map: src/app/Security/InboundRoutingKey.php loads the key; src/application_runtime.php creates and verifies tags; src/inbound_email_helpers.php enforces routing and attribution; src/engagement_email_helpers.php normalizes outbound subjects.